

4.2 - TLS e mTLS em sistemas distribuídos

Confiança verificável entre cada componente

O handshake TLS em quatro passos

Como dois sistemas estabelecem um canal seguro

- **Cliente e servidor negociam versão e cipher suite**
 - Define qual algoritmo simétrico protegerá a sessão
- **Servidor apresenta certificado assinado por uma CA**
 - Cliente valida a cadeia de confiança até a raiz
- **As partes derivam uma chave de sessão compartilhada**
 - A partir daqui o tráfego é simétrico e rápido
- **TLS garante confidencialidade, integridade e autenticidade**
 - Autenticidade só do servidor, não do cliente, no TLS padrão

Terminação no balancer ou no serviço

TLS termina no load balancer

- Descriptografa na borda, simplifica os serviços
- Tráfego interno em texto simples na rede
- Menos custo de CPU nos serviços
- Confia que a rede interna é segura

TLS de ponta a ponta com mTLS

- Cada serviço prova identidade ao outro
- Tráfego interno criptografado e autenticado
- Mais custo de CPU e de certificados
- Não confia na rede, confia na identidade

A pergunta do questionário de segurança

- **Primeiro cliente enterprise envia questionário de compliance**
 - Pergunta se todo tráfego interno é criptografado

LUNALOG

Em 2023, o primeiro cliente enterprise da LunaLog enviou um questionário de segurança com uma pergunta direta sobre se toda a comunicação entre os componentes internos era criptografada. A resposta honesta era não: o tráfego entre microsserviços usava HTTP puro, porque estava dentro da VPC. Ana achava que a fronteira da VPC já bastava como proteção. O cliente explicou que, para os requisitos de compliance dele, rede privada não substitui criptografia. Foi nesse momento que mTLS via service mesh entrou no roadmap de segurança da empresa.

mTLS é o padrão do zero trust

- mTLS adiciona a autenticação do cliente ao handshake
- Cada serviço apresenta e valida certificado mutuamente

Em ambientes zero trust, a rede nunca é zona de confiança. mTLS torna a identidade do serviço, não o endereço de rede, a base da autorização de tráfego.

- Service mesh aplica mTLS sem mudar código da aplicação

Certificados em escala exigem automação

- **Certificado manual não sobrevive a dezenas de serviços**
 - Renovação esquecida derruba comunicação em produção
- **Certificados de vida curta reduzem janela de comprometimento**
 - Validade de horas exige emissão e rotação automáticas
- **CA interna emite identidades para cada workload**
 - SPIFFE padroniza identidade de workload entre plataformas
- **Automação de renovação é requisito operacional, não opcional**



Você protegeu a comunicação em movimento. Mas e os dados que ficam parados, em disco, em banco, em object storage? E quando precisar trocar a chave que protege anos de dados acumulados, vai recriptografar tudo? Existe um padrão que resolve isso sem tocar em um único byte armazenado.

Criptografia em repouso, em trânsito e envelope encryption